Contoso(주) · 사내 규정

정보보안 및 생성형 AI 사용 지침

문서번호 **SEC-003** 소관 **정보보호팀** 개정일 **2026-04-01** 등급 **내부**

1. 정보 등급

등급	예시	취급 원칙
공개	보도자료, 제품 카탈로그	제한 없음
내부	사내 규정, 일반 업무 문서	사내망·승인된 서비스에서만 사용
기밀	미공개 사업 계획, 원가, 고객 계약 조건	필요 인원에게만 공유, 사전 승인 필요
극비	M&A, 핵심 소스코드, 인사평가 결과	원칙적으로 AI 서비스 입력 금지

2. 생성형 AI 사용 원칙

- 업무에는 사내 승인 서비스인 'Contoso AI'(Microsoft Azure 기반)만 사용합니다.
- 외부 공개형 생성형 AI 서비스에 업무 자료를 입력하는 것은 금지합니다(개인 계정 포함).
- 공개·내부 등급 자료는 포털에 입력할 수 있습니다. 기밀 등급은 정보보호팀의 사전 승인과 포털의 지정 지식 소스 안에서만 사용합니다.
- 극비 자료는 입력할 수 없습니다.

> 고객 개인정보(주민등록번호, 연락처, 주소 등 식별 가능한 정보), 미공개 재무정보, 인사평가, 핵심 소스코드는 입력 금지입니다. 꼭 필요하면 이름·연락처를 마스킹하거나 비식별화한 뒤 사용하세요.

3. 결과물 검증

- AI 답변은 반드시 사람이 검증합니다. 출처가 제시된 경우 원문을 확인합니다.
- 법무·재무·인사 관련 최종 의사결정의 단독 근거로 AI 답변을 사용하지 않습니다.

4. 사고 대응

개인정보나 기밀 정보가 유출되었거나 유출이 의심되면 1시간 이내에 정보보호팀(내선 7777)에 신고하고, 24시간 이내에 사고 보고서를 제출합니다.

5. 계정과 접근 통제

- 모든 업무 시스템은 Microsoft Entra ID 로그인(SSO)과 다단계 인증(MFA)을 필수로 합니다.
- 비밀번호는 12자 이상으로 설정하고 90일마다 변경합니다.
- AI 포털의 질의 로그는 1년간 보관하며, 개인정보는 마스킹하여 저장합니다.

6. 외부 반출

기밀 이상 문서를 외부로 전송하려면 DLP 승인을 받아야 합니다. USB 저장 장치는 사용할 수 없습니다.